

# SIMATS ENGINEERING

## ASSESSMENT TOOL 1- Enumeration Analysis

COURSE CODE: ITA1404

COURSE NAME: Ethical Hacking

### COURSE OUTCOME COVERED

**CO3:** *Analyse network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BL3)*

*Assessment Tool Weightage: 40%*

**QUESTIONS: 5**

**Total Marks:100**

1. A cyber security consulting company has been contracted to perform an initial security assessment of the publicly accessible server **scanme.nmap.org**. Before conducting any vulnerability assessment, the client requires a detailed enumeration report. Using **Nmap**, perform host discovery, TCP port scanning, service version detection, operating system fingerprinting, and default script scanning on **scanme.nmap.org**. Analyze all identified ports and services, determine their business purpose, and evaluate whether they are necessary for public access. Discuss how a threat actor could utilize the information gathered during enumeration to launch further attacks such as service exploitation, brute-force attacks, or vulnerability discovery. Prepare a technical report summarizing your findings, attack surface analysis, risk assessment, and recommendations for securing the server.
2. The security team has deployed a deliberately vulnerable Linux server, **192.168.56.101 (Metasploitable 2)**, in an isolated laboratory environment to train penetration testers. As part of the pre-engagement reconnaissance phase, use **Nmap** to perform comprehensive enumeration of **192.168.56.101**. Identify all open ports, running services, service versions, and operating system information. Analyze the purpose of each service and determine which services could provide potential entry points for an attacker. Categorize the discovered services into High, Medium, and Low risk levels based on their exposure and functionality. Explain how the enumeration results could guide a penetration tester in selecting potential attack vectors and exploitation strategies.
3. A financial organization wants to assess the security posture of a Windows workstation located at **192.168.56.102** before connecting it to the production network. Using **Nmap**, enumerate **192.168.56.102** to identify active ports, network services, file-sharing protocols, remote management services, and operating system details. Analyze whether the discovered services comply with the principle of least privilege and identify any services that may unnecessarily increase the attack surface. Discuss how an attacker could leverage the identified services for reconnaissance, lateral movement, or unauthorized access. Based on your findings, propose a set of security hardening measures to improve the system's resilience against cyberattacks.

4. An organization hosts a web application on **192.168.56.103 (OWASP Juice Shop Server)** and plans to conduct a full penetration test. Before the testing phase begins, the security team must understand the server's network exposure. Using **Nmap**, perform a detailed enumeration of **192.168.56.103**, including host discovery, port scanning, service version detection, operating system fingerprinting, and web service identification. Analyze the discovered services and determine how they support the hosted web application. Evaluate the risks associated with exposed web services, administrative interfaces, and supporting services. Explain how the information gathered during enumeration could be used to identify potential vulnerabilities in the web application environment and recommend measures to minimize exposure
5. The network gateway device at **192.168.56.1** serves as the primary access point between the internal laboratory network and external networks. The network administrator suspects that unnecessary management services may be exposed. Using **Nmap**, conduct a comprehensive enumeration of **192.168.56.1**, including port scanning, service detection, operating system fingerprinting, and script-based enumeration. Identify all exposed management interfaces, network services, and accessible resources. Analyze the security implications of exposing services such as SSH, Telnet, SNMP, HTTP, or HTTPS management interfaces. Discuss how attackers could exploit misconfigured management services to gain unauthorized access to the network infrastructure. Based on your analysis, recommend security controls and best practices to secure the gateway device and reduce the risk of compromise.

**Code of Conduct:**

*I S Venkata Abhishek(192311053)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

**Signature of the student:Abhishek**

### RUBRICS FOR CALCULATION

| Criteria                 | Weightage (%) | Level 4<br>(Exemplary)                                                      | Level 3<br>(Proficient)                     | Level 2<br>(Developing)                      | Level 1<br>(Beginning)                  | Mark |
|--------------------------|---------------|-----------------------------------------------------------------------------|---------------------------------------------|----------------------------------------------|-----------------------------------------|------|
| Conceptual Understanding | 20%           | Demonstrates strong understanding of underlying concepts in the simulation  | Shows good understanding with minor gaps    | Partial understanding; some misconceptions   | Lacks understanding of key concepts     |      |
| Model Design             | 25%           | Develops accurate, well-structured simulation/model independently           | Develops correct model with minor errors    | Model is incomplete or requires guidance     | Unable to develop a proper model        |      |
| Tool Usage               | 20%           | Uses simulation tools effectively with correct setup and execution          | Uses tools with minor errors or guidance    | Limited ability to use tools properly        | Unable to use simulation tools          |      |
| Analysis of Results      | 20%           | Provides clear, logical analysis and meaningful interpretation of results   | Analysis is reasonable with minor gaps      | Superficial analysis; limited interpretation | Unable to analyze or interpret results  |      |
| Documentation            | 15%           | Presents results clearly with proper documentation and structured reporting | Documentation is adequate with minor issues | Poorly organized or incomplete documentation | No proper documentation or presentation |      |

# Q1. Enumeration of scanme.nmap.org

## Aim

To perform host discovery, TCP port scanning, service/version detection, OS detection, and default NSE script scanning on the authorized target scanme.nmap.org.

## Tools Used

Nmap

Terminal/Command Prompt

Wireshark, if traffic analysis is required

## Procedure

First verify that the host is reachable: `ping scanme.nmap.org`

Perform host discovery: `nmap -sn scanme.nmap.org`

Perform TCP port scanning: `nmap -sS scanme.nmap.org`

Perform service/version detection: `nmap -sV scanme.nmap.org`

Perform OS detection: `sudo nmap -O scanme.nmap.org`

Perform default script scanning: `nmap -sC scanme.nmap.org`

A combined enumeration can be performed as: `sudo nmap -sS -sV -O -sC scanme.nmap.org`

## Analysis

The scan identifies the publicly exposed TCP ports and the services running on those ports. Version detection helps determine the specific software and version. OS detection attempts to identify the target operating system, while default NSE scripts provide additional information about the discovered services.

Each discovered service should be analyzed according to:

| Finding    | Analysis                                    |
|------------|---------------------------------------------|
| Open port  | Determines externally accessible service    |
| Service    | Identifies its purpose                      |
| Version    | Helps identify outdated/vulnerable software |
| OS         | Helps understand target platform            |
| NSE result | Provides additional service information     |

## Security Risks

An attacker could use enumeration results to:

- Identify vulnerable service versions.
- Search for known vulnerabilities.

- Identify unnecessary exposed services.
- Select appropriate attack vectors.
- Attempt password attacks against authentication services where applicable.
- Perform further reconnaissance.

## Recommendations

- Expose only services required for public operation.
- Keep software updated.
- Disable unnecessary services.
- Use firewall rules to restrict access.
- Monitor suspicious connection attempts.
- Perform regular vulnerability assessments.
- Apply least-privilege principles.

## Result

Nmap enumeration provides an understanding of the target's externally visible attack surface and helps identify services requiring further security assessment.

## Q2. Enumeration of Metasploitable 2 — 192.168.56.101

The assessment specifically identifies 192.168.56.101 as **Metasploitable 2 in an isolated laboratory environment**.

### Aim

To identify open ports, services, versions, operating-system information, and potential entry points.

### Commands

Host discovery:`nmap -sn 192.168.56.101`

TCP scan:`nmap -sS 192.168.56.101`

All TCP ports:`nmap -p- 192.168.56.101`

Service/version detection:`nmap -sV 192.168.56.101`

OS detection:`sudo nmap -O 192.168.56.101`

Default scripts:`nmap -sC 192.168.56.101`

Comprehensive enumeration:`sudo nmap -p- -sV -O -sC 192.168.56.101`

### Analysis

Metasploitable 2 is deliberately vulnerable, so the scan is expected to reveal numerous network services.

The student should document the actual output in this format:

| Port                | Service       | Version       | Purpose         | Risk            |
|---------------------|---------------|---------------|-----------------|-----------------|
| Actual result       | Actual result | Actual result | Explain service | High/Medium/Low |
| Risk Classification |               |               |                 |                 |

#### High risk:

- Internet/network-facing services with known vulnerabilities.
- Unauthenticated or weakly protected services.
- Outdated services with known exploitable weaknesses.

#### Medium risk:

- Services requiring authentication but exposing useful attack surface.
- Older services without immediately confirmed critical vulnerabilities.

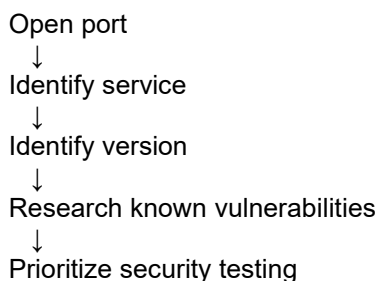
#### Low risk:

- Necessary services with appropriate configuration and no identified weakness.

### Attack-Surface Analysis

The enumeration results help a penetration tester prioritize testing.

For example:



#### Result

The Nmap scan provides the penetration tester with a map of the intentionally vulnerable server and helps prioritize potential entry points.

## Q3. Windows Workstation — 192.168.56.102

The assessment asks specifically for active ports, file sharing, remote-management services, OS details, least-privilege analysis, and hardening.

#### Aim

To enumerate the Windows workstation and determine whether unnecessary services increase its attack surface.

#### Commands

Basic scan: `nmap 192.168.56.102`

Service detection:nmap -sV 192.168.56.102

OS detection:sudo nmap -O 192.168.56.102

Default scripts:nmap -sC 192.168.56.102

Comprehensive scan:sudo nmap -sS -sV -O -sC 192.168.56.102

## Services to Examine

Pay particular attention to:

- **SMB/file sharing**
- **RDP**
- **WinRM**
- **RPC**
- **HTTP/HTTPS**
- Other remote-management services.

## Least-Privilege Analysis

For every open service, ask:

1. Is the service required?
2. Who needs access?
3. Is it accessible from the entire network?
4. Is authentication enabled?
5. Is the service securely configured?
6. If a service is unnecessary, it should be disabled.

## Security Risks

Attackers could use exposed services for:

- System reconnaissance.
- User/account enumeration.
- File-share discovery.
- Credential attacks.
- Lateral movement.
- Remote unauthorized access where vulnerabilities or weak authentication exist.

## Hardening

- Disable unnecessary services.
- Restrict SMB access with firewall rules.
- Secure RDP and remote-management services.
- Use strong authentication.
- Enable MFA where supported.
- Keep Windows and services patched.
- Restrict management interfaces to trusted networks.
- Monitor authentication and network activity.
- Apply least privilege.

## Result

The workstation should expose only services necessary for its intended purpose, with remote-management and file-sharing services restricted to authorized users and networks.

## Q4. OWASP Juice Shop — 192.168.56.103

The assessment identifies 192.168.56.103 as the **OWASP Juice Shop Server** and requires host discovery, port scanning, service detection, OS fingerprinting, and web-service identification.

### Aim

To enumerate the network exposure of the Juice Shop server before penetration testing.

### Commands

Host discovery:`nmap -sn 192.168.56.103`

Port scan:`nmap -sS 192.168.56.103`

All TCP ports:`nmap -p- 192.168.56.103`

Service detection:`nmap -sV 192.168.56.103`

OS detection:`sudo nmap -O 192.168.56.103`

Default scripts:`nmap -sC 192.168.56.103`

Combined:`sudo nmap -p- -sV -O -sC 192.168.56.103`

### Analysis

The important findings are:

- Open web ports.
- HTTP/HTTPS services.
- Web-server technology.
- Application-related services.
- Administrative interfaces.
- Other supporting services.

The actual ports and versions should be taken directly from your Nmap output.

### Security Risks

Exposed web services can allow attackers to investigate:

Web-server vulnerabilities.

Application vulnerabilities.



Outdated components.

Administrative interfaces.

Misconfigured supporting services.

Enumeration helps testers identify where further **authorized application security testing** should be concentrated.

## Recommendations

- Expose only required web services.
- Disable unnecessary administrative interfaces.
- Keep web-server components updated.
- Use HTTPS where appropriate.
- Restrict administrative access.
- Apply firewall rules.
- Monitor web and network activity.
- Regularly perform vulnerability assessments.

## Result

Nmap enumeration establishes the network attack surface supporting the Juice Shop application and provides information for subsequent authorized penetration testing.

## Q5. Network Gateway — 192.168.56.1

The question specifically requires enumeration of management interfaces and analysis of **SSH, Telnet, SNMP, HTTP, and HTTPS**.

### Aim

To identify exposed gateway services and determine whether unnecessary management interfaces are accessible.

### Commands

Basic port scan:`nmap 192.168.56.1`

All TCP ports:`nmap -p- 192.168.56.1`

Service detection:`nmap -sV 192.168.56.1`

OS fingerprinting:`sudo nmap -O 192.168.56.1`

Default scripts:`nmap -sC 192.168.56.1`

Comprehensive enumeration:`sudo nmap -p- -sV -O -sC 192.168.56.1`

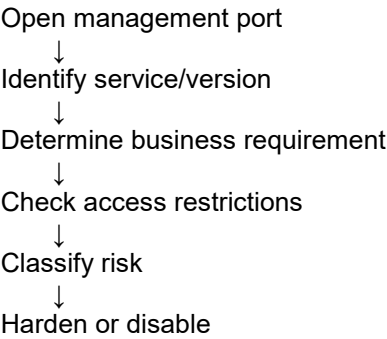
### Services and Risks

| Service | Typical purpose               | Security concern                                               |
|---------|-------------------------------|----------------------------------------------------------------|
| SSH     | Secure remote administration  | Brute-force attempts, weak credentials, excessive exposure     |
| Telnet  | Remote administration         | Credentials/data transmitted insecurely                        |
| SNMP    | Network monitoring/management | Information disclosure if poorly configured                    |
| HTTP    | Web management                | Unencrypted management traffic                                 |
| HTTPS   | Secure web management         | Misconfiguration, weak authentication, exposed admin interface |

## Analysis

The administrator should determine whether each management service is actually required.

For example:



## Security Risks

An attacker who discovers exposed management services may:

- Identify the gateway technology.
- Determine software versions.
- Enumerate network information.
- Attempt unauthorized authentication.
- Exploit vulnerable services.
- Use weakly configured management interfaces as an entry point.

**Telnet** is particularly undesirable for sensitive administration because it does not provide the protection expected from encrypted remote administration.

## Security Controls

- Disable Telnet and use secure remote administration.
- Restrict SSH access to authorized management networks.
- Use strong authentication and preferably MFA where supported.
- Disable unnecessary HTTP management access.
- Use properly configured HTTPS.
- Secure SNMP and avoid insecure/default community configurations.
- Apply firewall/ACL restrictions.

- Keep gateway firmware/software updated.
- Monitor management login attempts.
- Separate management traffic from normal user traffic.

## **Result**

The gateway should expose only essential management services, and those services should be restricted to authorized administrators and trusted management networks.